RED SUMARIMPACTO

Informe técnico de evolución del Backend

Versión 1.1 · Desarrollo Web Backend · IFTS N.º 29

Grupo 6 — Comisión A

Iván Ezequiel Shifman · Ángel Sabato · Flavio Rinaldi · Marcelo Zárate

Documento base para acompañar la entrega técnica. Debe completarse con evidencias reales de ejecución, despliegue, video grupal y validación de los integrantes.

1. Objetivo y alcance

La versión 1.1 evoluciona la aplicación existente de Red SumarImpacto, conservando Node.js, Express, MongoDB/Mongoose y las vistas Pug. El objetivo es reforzar la seguridad, administrar usuarios y roles, digitalizar la rendición de gastos y mejorar la trazabilidad de fondos sin reescribir innecesariamente la solución previa.

Alcance incorporado

- Autenticación Passport Local y Passport JWT; access token y refresh token rotativo.
- Contraseñas con bcrypt, cuentas administradas y autorización por seis roles.
- Aislamiento de proyectos y rendiciones por organización para referentes territoriales.
- Carga de comprobantes JPG, PNG, WEBP y PDF, con límite de 5 MB y validación de firma binaria.
- Circuito de aprobación de gastos según RF-02 y saldo comprometido.
- Campañas, reportes de recaudación, exportación PDF y cola de notificaciones a donantes.
- Vistas Pug para login, administración, usuarios, rendiciones, campañas y tutorial.
- Validaciones, manejo centralizado de errores, controles HTTP y documentación de migración.

2. Arquitectura

Se mantiene una arquitectura MVC con capa de servicios. Las rutas declaran autenticación, roles y validaciones; los controladores gestionan HTTP y vistas; los servicios concentran reglas de negocio; los modelos mantienen invariantes y persistencia; los middlewares resuelven autenticación, autorización, carga de archivos, seguridad y errores.

Stack: Node.js 20+, Express 4, MongoDB/Mongoose, Passport, JWT, bcryptjs, express-validator, Multer, Helmet, CORS, express-rate-limit, Pug, Nodemailer y PDFKit.

3. Roles y responsabilidades

Rol	Responsabilidad principal
Administrador	Gestión técnica, usuarios y entidades; lectura general. No aprueba rendiciones.
Referente territorial	Consulta proyectos de su organización y carga comprobantes propios.
Auditoría	Revisa, aprueba u observa rendiciones; deriva a Mesa las superiores al umbral.
Mesa Coordinadora	Resuelve las rendiciones derivadas por Auditoría.
Administración	Gestiona donantes/donaciones y consulta rendiciones en modo lectura.
Trabajo Social	Gestiona organizaciones y proyectos.

4. Rendición digital y reglas RF-02

Cada rendición registra proyecto, monto, fecha, rubro, descripción, archivo y actores de carga/revisión/aprobación. El presupuesto del proyecto contiene total, período y rubros aprobados. Los gastos pendientes reservan saldo; los observados dejan de computarse como comprometidos.

Reglas básicas

1. La fecha del comprobante debe estar dentro del período del proyecto.
2. El rubro debe formar parte del presupuesto aprobado.
3. El monto no debe superar el saldo disponible.

Los valores iniciales de la elicitación son 5 % para autoaprobación, 30 % para intervención de Mesa y 5 % como tope mensual de aprobaciones automáticas. Se configuran mediante variables RENDICION_* y deben confirmarse con Mesa Coordinadora.

Hasta el umbral automático, una rendición con reglas básicas cumplidas puede aprobarse automáticamente si el acumulado mensual respeta el tope. Los demás casos pasan a Auditoría. Por encima del umbral de Mesa, Auditoría revisa y deriva a Mesa Coordinadora. Nadie puede resolver una rendición propia.

5. Campañas y notificaciones

Las donaciones pueden asociarse a campañas con meta y período. El reporte calcula total recaudado, cantidad de donaciones y avance de meta, considerando hasta los últimos doce meses, y permite exportar PDF.

Al aprobar una rendición se genera un evento persistente por donante que aportó al proyecto. Las preferencias inmediata, semanal y mensual agrupan eventos por destinatario. El worker SMTP reintenta hasta tres veces con intervalos de cinco minutos y envía enlaces firmados de 90 días a comprobantes aprobados.

6. Seguridad y manejo de errores

- bcrypt con factor 12; no existe registro público.
- Access token corto y refresh token rotativo; se persiste el hash SHA-256 del refresh token.
- Cookies HttpOnly, SameSite Strict y Secure en producción; API también acepta Bearer.
- Helmet, CORS allowlist, rate limiting y verificación de origen en solicitudes mutables.
- Validaciones con express-validator y Mongoose; campos de escritura con allowlists.
- ApiError y middleware central para errores de validación, MongoDB, JWT y Multer.

7. Pruebas y estado de verificación

Pruebas unitarias ejecutadas: 7 aprobadas, 0 fallidas. Cubren aprobación automática, tope mensual, derivación a Auditoría, intervención de Mesa, reglas básicas, importes inválidos y parametrización de umbrales RF-02.

Chequeo sintáctico: Node --check correcto sobre 54 archivos JavaScript. El script también compila las plantillas Pug cuando las dependencias están instaladas.

Limitación del entorno de edición: el registro npm no respondió y no fue posible instalar dependencias; por eso no se ejecutó la compilación Pug ni las pruebas de integración con MongoDB/SMTP. Tampoco se probó el despliegue real. No deben presentarse estos puntos como verificados.

8. Migración y puesta en marcha

1. Realizar backup de MongoDB.
2. Instalar dependencias con npm install y completar .env.
3. Generar secretos independientes de al menos 32 caracteres.
4. Crear el primer administrador con npm run create-admin.
5. En una base existente, ejecutar npm run migrate-v1.1.
6. Completar manualmente presupuesto, período y rubros de proyectos antiguos.
7. Asignar organización a cada referente territorial.
8. Configurar SMTP, APP_BASE_URL y COMPROBANTE_LINK_SECRET para activar emails.
9. Ejecutar npm run check, npm test y la matriz de integración en staging.

9. Aspectos que requieren validación del equipo

- Confirmar con Mesa Coordinadora los umbrales de RF-02 antes de producción.
- Validar con MongoDB Atlas y SMTP la concurrencia y el objetivo de 1.000 eventos/minuto; el worker incluido es de un solo proceso.
- Verificar pruebas negativas de roles, aislamiento por organización, archivos y transiciones de estados.
- Completar URL de despliegue, video grupal y evidencias de ejecución real.
- Declarar el uso de IA de forma transparente y revisar el contenido con todos los integrantes.

Este informe es una base técnica para la entrega y no reemplaza el PDF final solicitado por la cátedra ni las evidencias que debe producir el grupo.